security.md

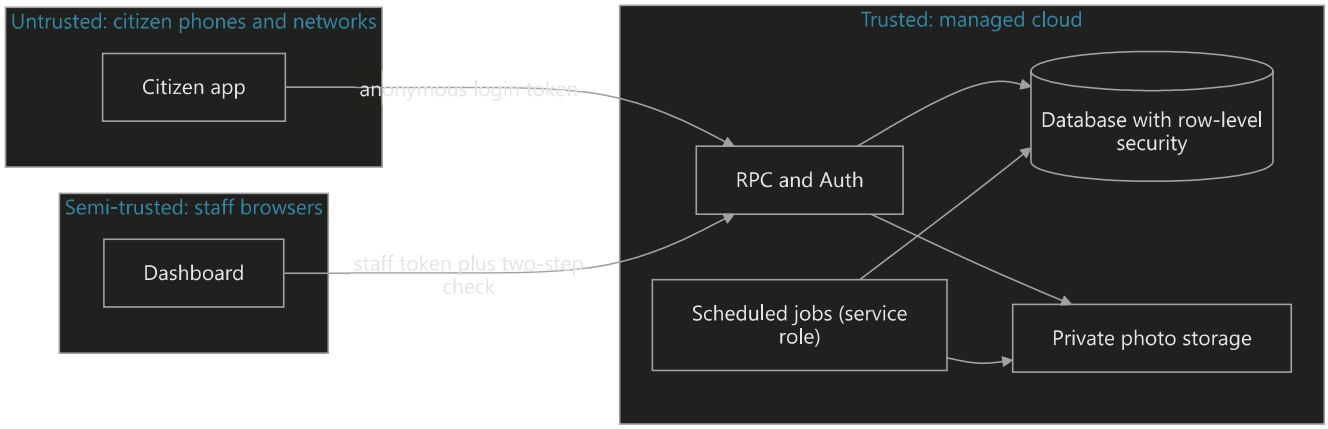
> **CivicSync · Security, Privacy and Compliance** Version 1.0-rc1 · 28 Oct 2026 · Owner: Backend Lead (Manindra Shukla) · Co-owner: Team Leader (Aayush) **Not legal advice.** The compliance notes in §6–§7 are a working checklist for the team. A lawyer or the institution's legal cell must review them before any real pilot with real citizens (**Q-05**).

1. What we are protecting

Asset	Why it matters	Sensitivity
Citizen photos	May show faces, number plates, homes, children	High
Precise location and time at capture	Can reveal where someone was and when	High
Account identifiers and push tokens	Could link reports to a person or device	Medium
Staff accounts and sessions	Could change ticket status, see photos	High
Ticket data and rankings	Public-interest data; tampering misdirects repair crews	Medium
Rule configuration (`rule_config`)	Changing weights could quietly re-rank the city	Medium
Service keys and API keys	Full database or billing access	Critical
The ML model file	Tampering could mislabel hazards	Low–Medium
Our reputation and the municipality's trust	One leak can end a pilot	High

Design stance: collect as little as possible; keep people pseudonymous; give each person the smallest access they need; make every staff action traceable.

2. Trust boundaries



Rule: the phone and the browser are never trusted to decide anything that matters. The phone's class guess, severity and location are *claims*. The database function checks them, applies the rules in `rules.md`, and an officer makes the final call.

---

3. Threat model

Method: a light STRIDE pass on each boundary. Likelihood and impact are the team's judgement (L / M / H) and are re-scored each sprint.

ID	Threat	Example	Mitigation	Risk before → after
T1	**Fake or spam reports**	Someone sends 500 junk photos	Rate limit of 10 reports/day per account (`rules.md` §2.9); exact-copy photo check; officers verify; `test_or_misuse` rejection; accounts can be blocked	H → M
T2	**Location spoofing**	Fake GPS to flood a ward	Mock-location flag; no auto-verification from flagged reports (`rules.md` §3.2); officer review; compare with ward polygons	M → L
T3	**Photo reuse or stock photos**	Same image sent from many places	SHA-256 check; near-duplicate review in dashboard; EXIF time check at capture	M → M
T4	**Coordinated false corroboration**	Many accounts report a fake hazard to raise priority	Corroboration needs 3 *distinct* reporters and clean flags; officers see "verified by several reports" and can reject; anomaly alert if one cell gets > N reports/hour	M → L
T5	**Account takeover (staff)**	Stolen password	Invite-only accounts, mandatory two-step (TOTP), strong passwords, 30-minute idle timeout, immediate disable, audit log	H → L
T6	**Over-broad access**	A Ward Officer sees another ward or a Crew Lead exports data	Row-level security by ward; role matrix in §4.3; CSV export only for City Admin and re-authenticates; tests in CI	H → L
T7	**Photo leak via links**	A shared or guessed photo URL	Private bucket; signed links valid for 15 minutes; no public listing; links are generated per request and checked against the viewer's ward	H → L
T8	**Key exposure**	Service-role key in a public repo or app	Only the public (anon) key is in apps; service key only in CI/server secrets; secret scanning in CI; keys rotated on any suspicion	H → L

ID	Threat	Example	Mitigation	Risk before → after
T9	**API abuse and scraping**	Bots hitting "nearby hazards"	Result cap (50), radius cap (500 m), rate limits, no photos or reporter info in that endpoint	M → L
T10	**Cost exhaustion**	Someone burns the Maps quota or storage to cause a bill	Maps API key restricted to our app ID and dashboard domain; per-SKU quotas and budget alerts at 50% and 80%; storage alerts at 70%; Pro plan spend cap on (where available)	M → L
T11	**Tampered model or app**	Modified APK with a different model	Treat on-device output as a claim; server rules and officer review; sign release builds; model checksum recorded per release	L → L
T12	**Malicious content in notes**	Notes containing scripts or instructions	Plain-text only, length cap, output-encoded everywhere; never rendered as HTML	M → L
T13	**Insider misuse**	An officer browses photos out of curiosity	Staff photo views are written to `audit_log`; periodic review; break-glass process for Platform Admin	M → M
T14	**Privacy failure**	A photo shows a face or plate that isn't blurred	On-device blur (best-effort), restricted viewing, shorter retention for `privacy_blur_failed`, report-a-privacy-problem button	M → M
T15	**Dependency or supply-chain attack**	A compromised package	Pinned versions, lock files, Dependabot, review for new packages, install packages only 14+ days after release where practical	M → L
T16	**Prompt injection through developer AI tools**	An AI assistant connected to the database reads a citizen's note that says "ignore your instructions and..."	Treat all database content as data; connect assistants only to a **dev** project with seeded fake data and read-only scope; never expose the service key or production data to an assistant (§8)	M → L

ID	Threat	Example	Mitigation	Risk before → after
T17	**Service pause or outage**	Free project paused	Pro plan before beta; health checks; offline queue protects reports	M → L
T18	**Loss of data**	Accidental delete	Backups; migration review; soft-delete for tickets; staff can't hard-delete	M → L

4. Authentication and role-based access

4.1 How people sign in

Who	Method	Notes
Citizen	**Anonymous sign-in** on first launch (a random account tied to the app install). Optional upgrade to **Google sign-in** to keep reports across devices.	No name, phone or email is required to report (**D-06**). We avoid phone OTP in v1 because SMS delivery costs money and needs sender registration, which would endanger the <$50/month budget. Trade-off: reinstalling the app loses reports unless the person signs in with Google.
Staff (Ward Officer, Crew Lead, Zonal Engineer, City Admin)	**Invite-only** email account, strong password (≥ 12 characters), **mandatory TOTP two-step check**	Invites are sent by a City Admin or Platform Admin. Disabling an account takes effect on the next token refresh and the 1-hour token expiry.
Platform Admin (team members)	Same as staff, plus hardware-key or authenticator app, limited to 2 people	Uses the service role only from CI or a locked-down machine.

Sessions: staff access tokens last 1 hour; idle timeout 30 minutes; re-enter the two-step code to export data. Tokens are held in memory for the dashboard and in secure storage (Keystore) on the phone.

4.2 Row-level security (RLS) principles

- RLS is **enabled on every table**, with no table left open "for now".
- Default is deny. Policies are written per role.

- Staff policies check `profiles.role` and `profiles.ward_ids` against the row's `ward_id`.
- The dashboard and app use the public (anon) key plus the user's token. The service-role key is never in a client.
- Database functions that change state (`transition_ticket`, `merge_tickets`) re-check the role and ward inside the function, not just in the UI.
- Policies are covered by automated tests that try to break them (a citizen reading another's report; an officer opening another ward; a Crew Lead opening an unassigned ticket).

4.3 Permission matrix

✓ = allowed, ◐ = allowed within limits noted, – = not allowed.

Action	Citizen	Ward Officer	Crew Lead	Zonal Engineer	City Admin	Platform Admin
Submit a report	✓	–	–	–	–	–
See own reports and statuses	✓	–	–	–	–	–
See nearby open hazards (no photos, no people)	✓	✓	✓	✓	✓	–
See tickets	–	◐ own wards	◐ assigned to them	◐ their zone	✓ city	◐ metadata only
See report photos	–	◐ own wards	◐ assigned tickets	◐ their zone	✓ city	◐ break-glass only, logged
See who reported	–	–	–	–	–	– (pseudonymous)
Verify or reject	–	◐ own wards	–	◐ zone	✓	–
Assign to Crew Lead	–	◐ own wards	–	◐ zone	✓	–
Resolve with after-photo	–	◐ own wards	◐ assigned	–	–	–
Merge or split duplicates	–	◐ own wards	–	◐ zone	✓	–
Pause SLA clock	–	◐ own wards	◐ assigned	◐ zone	✓	–
Analytics	–	◐ own wards	–	✓ zone	✓ city	◐ aggregate only
CSV export	–	–	–	–	✓ re-authenticated	–

Action	Citizen	Ward Officer	Crew Lead	Zonal Engineer	City Admin	Platform Admin
Invite or disable staff	–	–	–	–	◐ city staff	✓
Edit `rule_config`	–	–	–	–	–	✓ (logged, reviewed)
Read audit log	–	–	–	–	◐ city	✓

---

5. Privacy of citizen photos and location

5.1 Principles

1. **Collect the minimum.** One photo, one capture location, one capture time. No contact list, no continuous location, no background tracking.
2. **The hazard's location is the thing we need.** We store where the *hazard* is, not where the *person* has been. There is no location trail.
3. **People stay pseudonymous.** Staff never see who reported. They see "3 reports".
4. **People in photos are not the subject.** The app tells the person to stand safely and not to photograph faces, and then tries to blur them anyway.

5.2 Technical measures

Measure	Detail
Face and plate blur on the phone	ML Kit face detection and on-device text recognition find faces and plate-like text; those areas are blurred *before* upload. Best effort: it can miss. Failures are flagged (`privacy_blur_failed`) and those photos are kept for half as long (`rules.md` §7). Budget: ⩽ 1 s per photo on RD-1.
Metadata stripped	Re-encoding to WebP removes EXIF (including embedded GPS). The location we keep is the separately captured, accuracy-tagged reading.
Private storage	Bucket is private; path includes the account id; upload allowed only into the person's own folder.
Short-lived viewing links	15-minute signed links; each staff view is logged.
Encryption	HTTPS/TLS for all traffic; storage and database encrypted at rest by the provider; Keystore-backed secure storage for tokens on the phone.
No third-party analytics with personal data	No advertising or behavioural analytics SDKs. Crash reports are free of photos and use a hashed user id.
Maps disclosure	Loading a Google map sends device and location information to Google. The privacy notice says so, and the map loads only after the welcome screen's agreement.
Server region	Supabase project in the Mumbai region where available (**D-12**). Firebase push and crash services and Google Maps process data outside India; the privacy notice says so.
Nearby-hazards endpoint	Returns class, status and number of reports only, within a 500 m radius and 50 results; no photos or reporter information.
Training use	Citizen photos are not used for model training unless the person opts in (`rules.md` §8.3).
Privacy button	Every report in "My reports" has "Tell us about a privacy problem". It notifies the Platform Admin and hides the photo pending review.

5.3 What the privacy notice must say (plain words)

What we collect, why, who can see it (ward staff only), how long we keep it, how to delete it, who to contact, that Google services are used, and that the photo may show people who haven't agreed to it, so we blur what we can. Written at a reading level a Class 8 student can follow, in English and Hindi (`design.md` §3).

---

6. Data retention, erasure and Indian data-protection expectations

6.1 Retention

The numbers are in `rules.md` §7. The reasoning:

- **Photos are the riskiest data and the biggest cost**, so they go first: 90 days after a fix, 30 days after a rejection.
- **The link to the person goes at 180 days after the fix.** After that the record is an anonymous hazard record.
- **Hazard records stay for 3 years** because response-time analytics need history (**A-08**).
- **Staff logs stay 12 months** so misuse can be investigated.
- **People can ask for deletion**, and we complete it within 30 days.

6.2 India's data-protection law: working notes

Checked against public summaries in October 2026. Verify against the official text.

Topic	What we understand	What we do
The law	The Digital Personal Data Protection Act, 2023, and the DPDP Rules, 2025 (notified 13–14 November 2025).	Treat the Act's principles as binding from day one (**A-11**).
Timing	Rules came into force in phases: a first set immediately, consent-manager provisions after about 12 months, and the main duties on notice, consent, security, breach reporting, children's data and erasure after about **18 months (around 13 May 2027)**.	The pilot will probably run *before* those duties are enforceable. We still build to them so the pilot data isn't a problem later.
Who is responsible	The "Data Fiduciary" decides why and how data is used. It might be Team Praxis (app and cloud), the municipality (for its tickets), or both.	Unresolved: **Q-05**. Settle in writing with the municipal partner before the pilot (a short data-sharing agreement).
Notice and consent	Consent must be free, specific, informed and a clear affirmative action; the notice must explain what, why, and how to exercise rights. Withdrawing consent should be as easy as giving it.	Welcome screen with plain-language notice and a clear "I agree" (not pre-ticked); "Delete my data" is one tap in Settings.
Purpose and minimisation	Use data only for the stated purpose; keep only what is needed.	Purpose: pass a road hazard to the city and show its status. No ads, no sale, no profiling.
Storage limitation	Erase data when the purpose is over, unless the law requires keeping it.	Retention schedule (`rules.md` §7).
Security safeguards	Reasonable safeguards such as encryption, access control, logging, backups, and keeping logs for a minimum period (we understand about one year).	§3–§5 above; audit log 12 months.
Breach response	Report a personal-data breach to the Data Protection Board and affected people; a detailed report to the Board within about 72 hours.	Incident plan in §9.
Children	Processing a child's (under 18) data generally needs verifiable parental consent.	Pilot is **18+ only** (self-declared; **A-10**). Beta recruits adults

Topic	What we understand	What we do
		only. Known weakness: self-declaration is easy to bypass.
Rights	People can ask for access, correction and erasure, and can complain.	In-app "Help" with a named contact and 30-day response (**Q-06** for the grievance contact).
Cross-border transfers	Generally allowed unless a country is restricted by the government.	Disclosed in the notice; Mumbai region for the main database.
Government use	State bodies carrying out public functions may rely on specific provisions.	Municipal partner's lawyers decide how they treat tickets; we keep citizen identity out of the municipal view anyway.
Older law	Until the corresponding old provisions are replaced, rules under the IT Act (for example on sensitive personal data) may still apply.	Ask the legal cell.

6.3 Other licence and terms obligations

- **Google Maps Platform terms:** don't store geocoding results beyond what is allowed; we do ward lookup with our own polygons (**D-08**).
- **OpenStreetMap data:** credit OSM and follow the Open Database Licence for any database we derive from it.
- **Datasets:** record each public dataset's licence (RDD2022 and others) before training and in the model's release notes.
- **Open-source code:** list copyleft dependencies (AGPL/GPL) in `tooling.md` §11 before use.

---

7. Compliance checklist (living)

#	Item	Owner	Due	Status
1	Privacy notice written (EN + HI) and reviewed	UX & Ops Lead + legal cell	Sprint 2	Open
2	Data-sharing agreement with municipal partner	Team Leader	Before beta	Open (**Q-05**)
3	Grievance contact named and shown in app	Team Leader	Sprint 4	Open (**Q-06**)
4	"Delete my data" flow built and tested	Flutter Lead + Backend Lead	Sprint 4	Open
5	18+ gate on welcome screen	Flutter Lead	Sprint 1	Open
6	RLS test suite green in CI	Backend Lead	M2, M4	Open
7	Retention jobs built and tested on fake data	Backend Lead	Sprint 4	Open
8	Dataset licences recorded	CV Lead	Sprint 1	Open
9	Incident plan tested with a tabletop drill	Team Leader	Before beta	Open
10	Maps key restrictions and budget alerts on	Backend Lead	Sprint 2	Open

---

8. Secure development practice

- **Branch protection:** pull requests with at least one review; no direct pushes to the main branch.
- **Secrets:** never in the repository; CI secrets only; secret scanning on every push.
- **Dependencies:** pinned versions and lock files; automated update PRs; review new packages; prefer well-maintained, permissively licensed ones.
- **Migrations:** every database change is a reviewed SQL migration file with a matching RLS test.
- **Static checks:** `flutter analyze`, `dart format`, Python linting, SQL linting.
- **Web checks:** an automated security scan of the dashboard before the beta; follow OWASP's web and mobile verification checklists as a guide.

- **AI and MCP tooling:** see `tooling.md` §10. In short: dev project only, fake data, read-only scope, least-privilege tokens, review every proposed change, and treat database text as data, not instructions (T16).

---

9. Incident response (small-team version)

Step	Action	Who	Target
1	**Detect and tell**: anyone who suspects a leak or misuse messages the Team Leader and Backend Lead	Anyone	Immediately
2	**Contain**: disable the account, rotate keys, hide the photos, pause the feature	Backend Lead	Within 1 hour
3	**Assess**: what data, whose, how many, since when	Backend Lead + Team Leader	Within 24 hours
4	**Notify**: municipal partner, and, where the law requires, the Data Protection Board and affected people (a detailed Board report is expected within about 72 hours)	Team Leader + legal cell	As required
5	**Fix and learn**: root cause, patch, a test that would have caught it; entry in `memory.md`	Backend Lead	Within 7 days

Break-glass access: if a Platform Admin must view a citizen photo (for example for a privacy complaint), they record the reason first; the view is logged and reviewed weekly.

---

10. Security acceptance tests

Test	Pass condition	Gate
Citizen A tries to read Citizen B's reports	Denied	M2
Ward Officer for Ward 1 opens a Ward 2 ticket	Denied	M4
Crew Lead opens an unassigned ticket	Denied	M4
Staff login without the second step	Denied	M4
Photo link used after 15 minutes	Denied	M2
Anonymous user calls a staff-only function	Denied	M4
Client build scanned for the service key	Not found	Every release
A photo with a clear face and a plate	Blurred in the stored copy, or flagged	M3–M4
Request for 51+ nearby results or a 5 km radius	Capped	M4
11th report in one day from one account	Rejected with the kind message	M2
"Delete my data" request	Link removed; open-ticket photos deleted; completed within 30 days	Sprint 4

---

11. Document acceptance criteria

This document passes review when it meets the checklist for `security.md` in `loop.md` §3.